

Risk Scoring Report

Project: `vulnerable-invoice-service` · Stage 2 (NVD CVSS-weighted) · Generated 2026-07-09 · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality` · Source: `depscan-report.json` @ `61ed8c3`

Typosquat override. The formula is CVSS-driven and cannot natively express a supply-chain impersonation attack. `com.fastxml.jackson.core:jackson-databind` is therefore force-escalated to `CRITICAL` and ranked **#1** ahead of every CVSS-scored finding — it should be removed before any other remediation work starts.

Ranked remediation backlog (top 10 of 24)

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	<code>com.fastxml.jackson.core:jackson-databind</code>	2.9.8	CRITICAL	9.5	Typosquat (REMOVE)	remove — use <code>com.fasterxml.jackson.core:jackson-databind</code>
2	<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0, Log4Shell)	2.26.1
3	<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	HIGH	7.8	CVE-2019-14379 / CVE-2020-8840 (9.8, 45 CVEs total)	2.18.8
4	<code>mysql:mysql-connector-java</code>	8.0.30	HIGH	7.0	CVE-2023-22102 (8.3) + GPL-2.0 license violation	8.0.33
5	<code>com.google.guava:guava</code>	24.1.1-jre	MEDIUM	5.5	CVE-2023-2976 (5.5, NVD-confirmed)	32.0.0-android
6	<code>com.google.common:common-lang3</code>	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0
7	<code>commons-io:commons-io</code>	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.7
8	<code>org.apache.logging.log4j:log4j-api</code>	2.14.1	LOW	2.8	none — outdated only	2.26.1
9	<code>com.fasterxml.jackson.core:jackson-core</code>	2.9.8	LOW	2.2	none — transitive, no CVE	n/a
10	<code>com.fasterxml.jackson.core:jackson-annotations</code>	2.9.0	LOW	2.2	none — transitive,	n/a

no CVE

Full 24-dependency ranking (including transitive/test-only leaves, all **LOW**) is in `depscan-risk-report.json`.

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
com.fastxml...:jackson-databind (typosquat)	10.0 (policy)	8.0	2.0	9.5 (override)
log4j-core	10.0	8.0	2.0	7.8
jackson-databind (real)	10.0	8.0	2.0	7.8
mysql-connector-java	8.3	8.0	2.0	7.0
guava	6.0	7.0	2.0	5.5
commons-lang3	5.3	7.0	2.0	5.2
commons-io	5.3	7.0	2.0	5.2

Business criticality note. Only `log4j-core` / `log4j-api` have a located usage (grepped import of `org.apache.logging.log4j.LogManager` / `Logger` in `DiscountCalculator`, an internal order/discount batch-logic class → classified "Internal service/batch", +2). No other dependency is actually imported anywhere in `src/main/java` (this is a deliberately-seeded demo repo), so they default to criticality 2 (`criticality_source`: "default"). Test-only dependencies (junit family) are classified "Build/test tooling only" (+1).

Summary

Band	Count
CRITICAL	1
HIGH	3
MEDIUM	3
LOW	17

Priority recommendations

- P0** — Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` dependency (supply-chain attack vector; not a normal CVE).
- P0** — Upgrade `log4j-core` / `log4j-api` 2.14.1 → 2.26.1 (Log4Shell family, actively exploited in the wild; also fixes 5 additional CVEs up to CVE-2026-34480).
- P1** — Upgrade `jackson-databind` 2.9.8 → 2.18.8 or later (45 known CVEs, multiple critical RCE-class deserialization gadget chains).
- P1** — Upgrade `mysql-connector-java` 8.0.30 → 8.0.33 (CVE-2023-22102) **and** resolve the GPL-2.0 license-policy violation (swap for MariaDB Connector/J (LGPL) or the approved internal driver).
- P2** — Upgrade `guava` → 33.6.0-jre (major version — review for API breakage before merging).
- P2** — Routine bumps: `commons-lang3` 3.4 → 3.18.0+, `commons-io` 2.4 → 2.14.0+.
- P3** — Remove the plain-HTTP `internal-untrusted-mirror` repository from `pom.xml`.

Machine-readable source: `depscan-risk-report.json`. Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.